OFFSIDE LABS

ZAP Release 0.2.3

Smart Contract Security Assessment

October 2026

Prepared for:

Meteora

Prepared by:

Offside Labs

Sirius Xie



Contents

1 About Offside Labs **2**

2 Executive Summary **3**

3 Summary of Findings **5**

4 Key Findings and Recommendations **6**

4.1 Missing Validation of the Swap Amount Offset 6

5 Disclaimer **7**

1 About Offside Labs

Offside Labs is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers*, *operating systems*, *IoT devices*, and *hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple*, *Google*, and *Microsoft*, have protected digital assets valued at over **$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.

 **https://offside.io/**

 **https://github.com/offsidelabs**

 **https://twitter.com/offside_labs**

2 Executive Summary

Introduction

Offside Labs completed a security audit of *ZAP* smart contracts, starting on September 22th, 2026, and concluding on October 14th, 2026.

Project Overview

Meteora Zap Release 0.2.3 adds support for Jupiter Aggregator version 2 swap instructions, including routes using shared accounts, while retaining existing routes for compatibility. It also updates DAMM V2 and DLMM integrations for Anchor 1.0.2.

Audit Scope

The assessment scope contains mainly the smart contracts of the zap program for the *Meteora ZAP* project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- Meteora ZAP
  - Codebase: `https://github.com/MeteoraAg/zap-program`
  - Release 0.2.3: `PR-56`
  - Commit Hash: 3b04a09de34e5a0c2ab8a41bb78eb59da6a37d18

The issues described in this report have been resolved by the following commit:

- Meteora ZAP Release 0.2.3
  - Codebase: `https://github.com/MeteoraAg/zap-program`
  - Commit Hash: 758bfe9093df1f1f6cc91a218aee302da29f90bc

We listed the files we have audited below:

- Meteora ZAP Release 0.2.3
  - programs/zap/src/constants.rs
  - programs/zap/src/instructions/ix_zap_in_damm_v2.rs
  - programs/zap/src/instructions/ix_zap_out.rs
  - programs/zap/src/instructions/zap_in_dlmm/ix_zap_in_dlmm_for_initialized_position.rs
  - programs/zap/src/instructions/zap_in_dlmm/ix_zap_in_dlmm_for_uninitialized_position.rs
  - programs/zap/src/lib.rs
  - programs/zap/src/state/user_ledger.rs

Findings

The security audit revealed:

- 0 critical issue
- 0 high issue
- 0 medium issue
- 1 low issues
- 0 informational issue

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.

3 Summary of Findings

ID	Title	Severity	Status
01	Missing Validation of the Swap Amount Offset	Low	Fixed

4 Key Findings and Recommendations

4.1 Missing Validation of the Swap Amount Offset

Severity: Low	Status: Fixed
Target: Smart Contract	Category: Data Validation

Description

In `zap_out` IX, it validates the downstream program and IX discriminator before writing the calculated swap amount into the payload at the `ZapOutParameters.offset_amount_in` .

However, the offset validation only checks that the write fits within the payload. It does not prevent overlapping the first eight discriminator bytes. Setting the offset to `zero` replaces the discriminator entirely with the little endian swap amount. The modified payload is then invoked without revalidating its discriminator.

If the encoded amount matches another valid discriminator in the same approved program, the invocation can target an IX outside Zap's whitelist, provided its arguments and accounts satisfy downstream validation.

Impact

A caller can bypass the swap IX whitelist and make `zap_out` execute a non-whitelisted instruction. Execution remains limited to approved programs and existing signer privileges.

Recommendation

It is recommended to whitelist the valid amount offset together with each program and instruction discriminator, deriving the offset from the payload layout where necessary.

At minimum, require `ZapOutParameters.offset_amount_in >= 8` and retain the existing bounds check to prevent overwriting the discriminator.

Mitigation Review Log

Fixed in the commit 607eabee04ca91769accf7c39db0057bc0c7267b.

5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

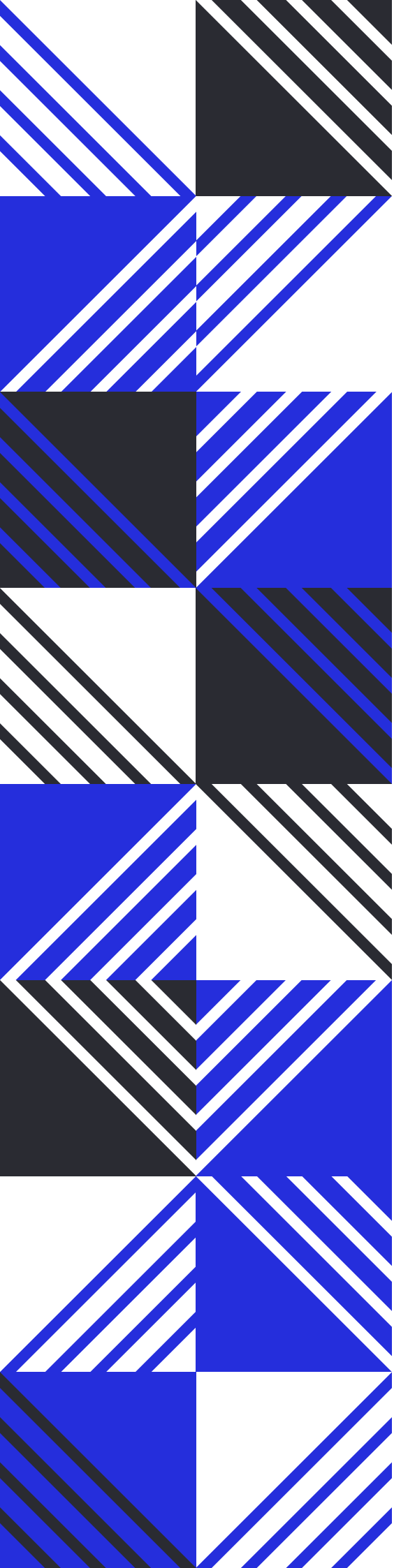
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



OFFSIDE LABS

https://offside.io/

https://github.com/offsidelabs

https://twitter.com/offside_labs